Notes de frais automatiques

Protection des données — description du traitement et demande d'avis de la DPO

Responsable	Yannick Pezeu
Date, version	30.09.2026, version 1.0
Service	https://expert-finder.epfl.ch/notes-de-frais
Pour essayer	Vous pouvez tester le service vous-même : ouvrez l'adresse ci-dessus, connectez-vous avec votre compte EPFL, puis saisissez le mot de passe de la phase de test, **communiqué dans le courriel d'envoi**. Installez le favori, ouvrez My Travel and Expenses dans sesame et cliquez dessus. La note est créée en brouillon dans votre propre sesame : vous pouvez la supprimer ensuite. Les compteurs d'usage sont visibles sur la page `/stats`.
État	Déployé ; accès par **connexion EPFL (Entra ID) et mot de passe de la phase de test** ; utilisé uniquement par l'équipe du projet. Aucun pilote avec des utilisateurs avant votre avis.
Destinataire	Déléguée à la protection des données de l'EPFL (un dossier distinct est adressé à la cybersécurité)

1. En bref

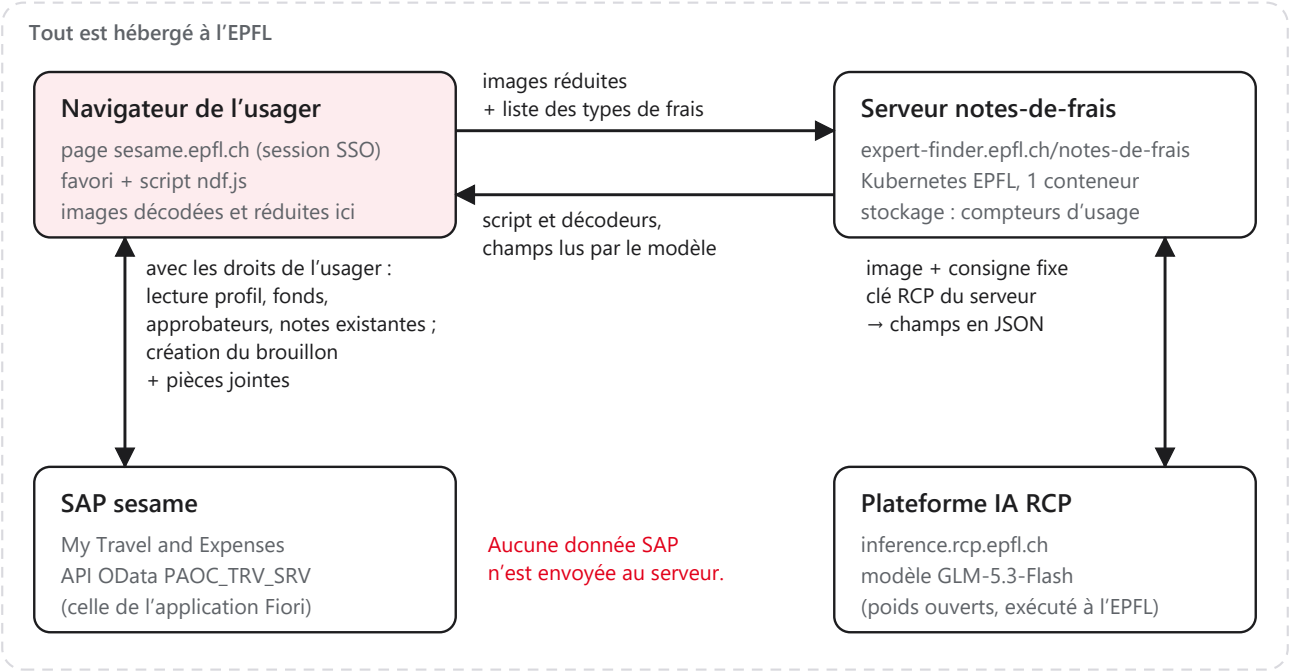
L'outil aide les collaborateurs à saisir leurs notes de frais de voyage dans My Travel and Expenses (sesame). Aujourd'hui, chaque frais est saisi à la main et le justificatif joint. L'outil lit les justificatifs avec un modèle d'IA et prépare la note ; **la finalité, le système (SAP) et les destinataires ne changent pas**.

- La note est créée **en brouillon** : la personne relit chaque ligne, corrige et soumet elle-même. Aucune décision automatisée.
- Les justificatifs sont lus par un modèle exécuté **sur la plateforme RCP de l'EPFL** : aucun envoi à un fournisseur d'IA externe.
- **Rien n'est conservé** par le service : images traitées en mémoire le temps de la lecture (quelques secondes), logs limités aux erreurs techniques, sans identité. Seuls des **compteurs d'usage** sont gardés (nombre de personnes, d'appels et de jetons), avec des **empreintes pseudonymisées** pour compter les personnes ; détail au chapitre 3.
- **Aucune donnée SAP ne quitte le navigateur** : profil, fonds, approbateurs et notes existantes sont lus et utilisés dans la page, jamais transmis à notre serveur.
- **Connexion avec le compte EPFL** : le service reçoit le nom, l'adresse e-mail et l'identifiant d'annuaire de la personne, gardés seulement dans son cookie de session (12 heures), jamais enregistrés.

Ce que nous vous demandons

1. Un avis sur ce traitement pour un **pilote restreint** avec quelques assistantes administratives.
2. S'il faut une inscription au registre des traitements (ou compléter l'inscription existante des notes de frais).
3. Si une analyse d'impact est nécessaire. À notre avis non (chapitre 5), mais nous suivrons votre appréciation.
4. Si l'information donnée aux utilisateurs (chapitre 6) suffit, ou ce qu'il faut y ajouter.

2. Fonctionnement et flux de données



1. L'usager ouvre sesame (connexion SSO EPFL habituelle), puis clique sur le favori « Note de frais ».
2. Le favori vérifie qu'il est bien sur sesame.epfl.ch, puis charge le script `ndf.js` depuis notre serveur. Si la personne n'est pas connectée, une petite fenêtre propose d'abord la connexion EPFL (puis, pendant la phase de test, un mot de passe) ; la session dure 12 heures.
3. Le script ouvre un panneau par-dessus la page et lit dans SAP, avec la session de l'usager, ce dont il a besoin : n° de personnel, types de frais autorisés, fonds, approbateurs, pays, et les notes existantes qui chevauchent le voyage (anti-doublon).
4. L'usager dépose ses justificatifs (photos, HEIC, TIFF, PDF). Ils sont décodés et réduits **dans le navigateur** (image JPEG de 1600 px au plus), puis envoyés à notre serveur. Un PDF de plusieurs pages est d'abord trié page par page (justificatif ou non, début de document) pour en séparer les justificatifs.
5. Le serveur ajoute une consigne fixe et la clé RCP, interroge le modèle sur la plateforme RCP de l'EPFL et renvoie les champs lus (date, montant, devise, fournisseur, type de frais, pays, ville).
6. L'usager relit et corrige le tableau, choisit fonds et approbateur, puis clique « Créer le brouillon ». Le script crée la note, joint les justificatifs et l'**enregistre en brouillon**. Il ne la soumet jamais : l'usager la relit dans sesame et clique lui-même sur Submit.

3. Personnes et données concernées

Personnes concernées

- Les **utilisateurs** : collaborateurs EPFL qui saisissent leurs propres frais (dans cette version, la note est toujours créée pour la personne connectée).
- Les **tiers figurant sur les justificatifs** : commerçants et prestataires ; parfois le nom d'invités sur une note de restaurant, le nom et l'adresse du voyageur sur une facture d'hôtel, les derniers chiffres d'une carte bancaire.

Données traitées, où elles vont, combien de temps

Donnée	Source → destination	Durée de conservation
Images des justificatifs (photos, PDF)	Usager → navigateur (réduites à 1600 px) → serveur → modèle RCP. Jointes à la note dans SAP, comme aujourd'hui.	Serveur : durée de la requête, aucune écriture sur disque. Plateforme RCP : rien n'est gardé. SAP : règles actuelles des notes de frais.
Champs lus (date, montant, devise, fournisseur, ville, pays, type de frais, description)	Modèle → navigateur → SAP après validation	SAP : règles actuelles. Ailleurs : aucune.
Profil SAP (n° de personnel, nom, SCIPER)	SAP → navigateur uniquement	Mémoire de la page, jusqu'à sa fermeture
Fonds, approbateurs, pays, types de frais	SAP → navigateur. Seule la liste des types de frais (non personnelle) est envoyée au serveur, pour que le modèle choisisse un type existant.	Mémoire de la page
Notes existantes de l'usager qui chevauchent le voyage (dates, lignes, montants)	SAP → navigateur, lecture seule, pour signaler un doublon	Mémoire de la page
Préférences : identifiants du dernier fonds et du dernier approbateur choisis	Navigateur (stockage local de sesame.epfl.ch)	Jusqu'à effacement par l'usager
Identité EPFL : nom, adresse e-mail, identifiant d'annuaire (connexion Entra ID ; ni accréditations ni droits)	Entra ID → serveur → cookie de session signé, dans le navigateur de la personne	12 heures (durée de la session) ; rien côté serveur
Logs techniques : erreurs seulement (type d'appel, durée, message d'erreur), sans identité ni pseudonyme ; rien pour un appel réussi ni une connexion	Serveur → logs du conteneur (Kubernetes), sur la machine du cluster qui l'exécute ; pas de collecte centralisée	Jusqu'au prochain déploiement au plus (le conteneur est alors recréé)
Compteurs d'usage (détail ci-dessous) : par jour, nombre de personnes distinctes et de nouvelles personnes, de connexions, d'appels, d'erreurs et de jetons ; par mois, nombre de personnes et de nouvelles personnes ; au total, nombre de personnes depuis la mise en service	Serveur → fichier sur un volume du cluster EPFL ; page `/stats` réservée aux personnes connectées	Sans limite (des nombres seulement)
Empreintes de comptage : HMAC de l'identifiant d'annuaire, avec une clé fixe, pour ne compter chaque personne qu'une fois	Même fichier ; la clé n'y figure pas. **Pseudonymisées** : l'administrateur du service peut les rapprocher des comptes EPFL (voir ci-dessous)	Liste globale : tant que le service existe. Listes du jour et du mois : effacées à la fin du jour ou du mois
Identifiant d'annuaire, comme clé des compteurs de quotas	Mémoire du serveur	24 h au plus ; effacé à chaque redémarrage
Adresse IP en clair, comme clé du compteur d'essais du mot de passe	Mémoire du serveur	15 minutes

Donnée	Source → destination	Durée de conservation
Cookie du mot de passe de la phase de test (jeton dérivé du mot de passe commun, sans identité)	Serveur → navigateur	30 jours ; supprimé au feu vert

Compteurs d'usage : ce qui est compté exactement

Ils servent à savoir combien de personnes utilisent l'outil, à quelle fréquence, et ce qu'il consomme sur la plateforme RCP. Ce sont uniquement des nombres, additionnés par jour (heure suisse) :

Compteur	Ce qu'il compte
Personnes	Nombre de personnes différentes qui ont utilisé le service ce jour-là (connexion ou appel au modèle).
dont nouvelles	Parmi elles, celles qui l'utilisaient pour la première fois.
Connexions	Nombre de connexions EPFL réussies.
Justificatifs lus	Nombre de lectures demandées au modèle : une par photo ou PDF d'une page, une par justificatif trouvé dans un PDF de plusieurs pages.
Pages triées	Nombre de pages de PDF de plusieurs pages classées avant lecture (justificatif ou non).
Erreurs	Nombre de lectures ou de tris qui ont échoué.
Jetons envoyés, jetons reçus	Quantité traitée par le modèle, dans son unité de mesure (les « jetons ») : à l'entrée la consigne et l'image, à la sortie la réponse. Valeurs déclarées par la plateforme RCP pour chaque appel.

Par mois, on compte aussi les personnes différentes et, parmi elles, les nouvelles. On en déduit le nombre de jours d'activité et le nombre moyen de jours d'utilisation par personne (somme des personnes de chaque jour, divisée par le nombre de personnes du mois). Enfin, un total donne le nombre de personnes différentes depuis la mise en service.

Jamais comptés ni enregistrés : les noms, adresses e-mail, SCIPER ou identifiants d'annuaire en clair, l'heure d'utilisation, combien de notes de frais ont été créées et ce qu'elles contiennent (montants, fournisseurs, types de frais, fonds), les justificatifs eux-mêmes, l'adresse IP, le navigateur.

Compter les personnes : des empreintes pseudonymisées : pour reconnaître une personne qui revient (et ne pas la compter comme nouvelle), le serveur garde une empreinte de son identifiant d'annuaire : HMAC-SHA256 avec une **clé fixe**, dérivée d'un secret du serveur qui ne figure pas dans le fichier. Une clé qui changerait chaque jour ou chaque mois ferait compter la même personne comme nouvelle à chaque changement. Le serveur tient trois listes d'empreintes : une **liste globale**, gardée tant que le service existe, pour le total et les nouvelles personnes ; une liste du **jour** et une du **mois** en cours, pour les personnes distinctes, effacées à la fin du jour ou du mois.

Ce que l'administrateur peut retrouver. Ces empreintes sont pseudonymisées, pas anonymes. L'administrateur du service (Yannick Pezeu), qui détient la clé et peut consulter l'annuaire EPFL, pourrait recalculer l'empreinte de chaque compte EPFL et savoir ainsi **quelles personnes ont utilisé le service depuis sa mise en service**, et lesquelles l'ont utilisé le jour ou le mois en cours. Il ne pourrait pas savoir quels jours passés elles sont venues (ces listes sont effacées), ni ce qu'elles ont fait (aucun contenu n'est enregistré). Personne d'autre ne le peut, la clé ne figurant pas dans le fichier. Ce rapprochement n'est pas fait et n'est pas nécessaire au service.

Qui les voit : la page `/stats` du service, réservée aux personnes connectées (aujourd'hui l'équipe du projet et les testeurs).

4. Destinataires et infrastructures

- **SAP sesame** : système existant des notes de frais ; l'outil y écrit ce que la personne aurait saisi à la main.
- **Entra ID (annuaire EPFL)** : connexion des utilisateurs, application « notesDeFrais » déclarée dans l'App Portal EPFL.
- **Serveur notes-de-frais** : cluster Kubernetes de l'EPFL (namespace epfl-chatbot), géré par le responsable du projet.
- **Plateforme RCP** : service d'inférence de l'EPFL (inference.rcp.epfl.ch). Modèle GLM-5.3-Flash, à poids ouverts, exécuté à l'EPFL. Notre service ne l'utilise pas pour entraîner un modèle. L'équipe RCP a confirmé que la plateforme ne garde aucune trace des requêtes (ni images ni réponses).
- Aucun sous-traitant externe, aucun CDN, aucune communication de données à l'étranger. Les bibliothèques de décodage (PDF, HEIC, TIFF) sont servies par notre serveur et s'exécutent dans le navigateur.

5. Principes de protection des données

Principe	Comment l'outil y répond
Finalité	Uniquement préparer la note de frais de la personne. Même finalité et même base que la saisie manuelle actuelle.
Proportionnalité, minimisation	Images réduites avant envoi ; seuls les champs utiles à la note sont extraits ; aucune donnée SAP envoyée au serveur ; connexion EPFL limitée au nom et à l'adresse e-mail (ni accréditations ni droits) ; aucune conservation par le service.
Exactitude	Chaque ligne est affichée pour relecture, avec des avertissements quand le modèle doute ; création en brouillon ; la personne soumet elle-même.
Décision automatisée	Aucune : l'outil propose, la personne décide.
Transparence	Page d'installation : « Les photos sont lues par un modèle d'IA hébergé à l'EPFL (RCP) et ne sont pas conservées par ce service. Elles sont jointes à la note dans sesame, comme si vous les aviez ajoutées à la main. »
Sécurité	HTTPS, connexion EPFL et mot de passe de la phase de test, clé du modèle côté serveur, aucun stockage de contenu. Détail et analyse des risques dans le dossier adressé à la cybersécurité.
Droits des personnes	Le service ne garde sur les personnes que des empreintes pseudonymisées (pour les compter) et des nombres. Les données enregistrées dans SAP suivent les processus existants.

Pourquoi une analyse d'impact ne nous paraît pas nécessaire

Le traitement existe déjà (notes de frais et justificatifs dans SAP) ; l'outil n'ajoute ni nouvelle finalité, ni nouveau destinataire hors de l'EPFL, ni conservation (hormis des compteurs et des empreintes pseudonymisées pour les établir), ni profilage, ni décision automatisée. Un justificatif peut exceptionnellement révéler une donnée sensible (par exemple un achat en pharmacie en voyage) ; il est alors traité comme aujourd'hui dans SAP, et seulement lu, sans être conservé, par le service.

6. Information des utilisateurs

Le texte cité au chapitre 5 figure sur la page d'installation du favori. Nous proposons d'ajouter, avant le pilote, une ligne dans le panneau de l'outil avec un lien vers une courte notice (données lues, où, combien de temps, contact). Nous reprendrons volontiers la formulation que vous recommandez.

7. Points ouverts

- **Saisie « pour le compte de »** (une assistante qui crée la note d'un voyageur) : envisagée, pas développée. L'API de SAP prévoit cette fonction ; nous vous la soumettrons avant de la développer.
- **Accès** : la connexion EPFL est ouverte au personnel ; un mot de passe commun réserve la phase de test aux testeurs et sera retiré à votre feu vert (ou l'application Entra restreinte à un groupe pour le pilote).

Avis de la DPO

☐ Favorable au pilote restreint, en l'état

☐ Favorable sous conditions (préciser ci-dessous)

☐ Défavorable

Conditions / remarques :

Nom, fonction, date :